

06. テスト仕様書

Version 1.0 (FIX) / 2026-08-17

1. テスト方針

実験導入フェーズであることを踏まえ、テストは「壊れると営業が止まる箇所」と「壊れても気付けない箇所」に絞って実施する。網羅率を追わない代わりに、下記の受入テストは導入前に必ず全件実施する。

種別	対象	実施方法	必須
受入テスト	機能要件 FR-01～FR-12	実機(スマホ+タブレット)による手動確認	必須
セキュリティ確認	なりすまし・権限・鍵の露出	手動+ブラウザ開発者ツール	必須
自動テスト	セッション検証・ステータス遷移・金額計算	pytest(バックエンド単体)	推奨
負荷テスト	—	実施しない(想定同時利用者が7卓程度のため)	対象外

自動テストを最小限にする判断

実験導入段階では仕様変更が頻繁に発生するため、UIの自動テストは維持コストが利益を上回る。一方、セッション検証・ステータス遷移・金額計算の3点は、「壊れていても画面上は正常に見えてしまう」ためpytestでの自動化を推奨する。

2. 受入テストケース(顧客機能)

ID	対応	手順	期待結果
AT-01	FR-01	開栓済みの卓T1のQRコードをスマホで読み取る	T1のメニュー画面が表示され、品切れ商品が表示されない
AT-02	FR-01	未開栓の卓T3のQRコードを読み取る	「ただいまご利用いただけません」の案内が表示され、注文できない
AT-03	FR-01	メニューの価格表示を確認する	店頭メニューと同じ金額が表示されている(例: ドリップコーヒーHOT 600円)
AT-04	FR-02	商品を2点カートに追加し、注文を送信する	送信が成功し、注文履歴画面へ遷移する
AT-05	FR-02	注文送信ボタンを連打する	二重に注文が登録されない
AT-06	FR-03	注文履歴を表示する	注文した商品と参考小計(税込)が表示され、会計はレジで確定する旨の注記がある
AT-07	FR-03	スタッフが提供済にした後、8秒以上待つ	履歴画面の表示が「準備中」から「提供済」に自動で変わる
AT-08	FR-04	「お会計呼出」をタップする	ボタンが「スタッフをお呼びしました」に変わり、連打できない
AT-09	FR-03	注文履歴画面をリロードする	ログイン等を求められず、同じ履歴が再表示される
AT-10	FR-01	同じ卓のQRを2台目のスマホで読み取り、注文する	2台目の注文も同じ伝票に追加され、双方の履歴に表示される

3. 受入テストケース(スタッフ機能)

ID	対応	手順	期待結果
AT-11	FR-05	正しいID/パスワードでログインする	ダッシュボードが表示される
AT-12	FR-05	誤ったパスワードでログインする	ログインできず、エラーが表示される
AT-13	FR-06	ダッシュボードを表示する	7卓すべてが実際の座席レイアウトどおりに配置されている
AT-14	FR-07	空席の卓を開栓する	卓が「使用中」になり、QR読取で注文可能になる
AT-15	FR-07	既に使用中の卓を、別端末から同時に開栓する	「既に開栓済みです」と表示され、伝票が二重に作られない
AT-16	FR-08	客が注文した後、4秒以上待つ	未提供リストに該当明細が受付順で表示される
AT-17	FR-08	未提供明細の「提供済」をタップする	提供済表示に変わり、客の履歴画面にも反映される
AT-18	FR-08	提供済にした明細の「Undo」をタップする	未提供状態に戻る
AT-19	FR-09	未提供明細を長押しして取消する	明細が取消され、参考小計から除外される
AT-20	FR-10	手入力で「テスト商品 1,000円」を追加する	該当卓の伝票に追加され、客の履歴にも表示される
AT-21	FR-11	品切れ管理で商品を品切れに設定する	客のメニュー画面から該当商品が消える
AT-22	FR-11	品切れを解除する	客のメニュー画面に再表示される
AT-23	FR-07	使用中の卓を会計クリアする	確認ダイアログの後、卓が「空席」に戻り、呼出表示も消える
AT-24	FR-07	会計クリア後、客が同じ画面で注文を試みる	「QRコードを再読み込みしてください」と表示され、注文できない
AT-25	FR-12	卓を開栓したまま日次バッチを実行する	対象卓が空席に戻り、checkout_staff_idがNULLのまま記録される

4. セキュリティ確認項目

本システムで最も重大なリスクは「他卓へのなりすまし」と「DBへの直接アクセス」である。以下は導入前に必ず全件実施すること。

ID	確認内容	手順	期待結果
ST-01	他卓へのなりすまし(書込)	T1のsession_tokenを使い、T2のorder_idに対して注文APIを直接呼ぶ	403 (SESSION_EXPIRED) が返り、T2に注文が登録されない
ST-02	他卓へのなりすまし(参照)	session_tokenを付けずに /orders/{他卓のid}/history を呼ぶ	403 が返り、他卓の注文内容が取得できない
ST-03	session_tokenの再発行	会計クリア→再開栓の後、クリア前のsession_tokenでAPIを呼ぶ	403 が返る(古いトークンが無効化されている)
ST-04	DBへの直接アクセス経路	ブラウザの開発者ツール(Network)で全通信を確認する	supabase.co への直接通信が1件も存在しない
ST-05	鍵の露出	フロントエンドのJSバンドルを "supabase" "service_role" "eyJ" で検索する	Supabaseの鍵が一切含まれていない
ST-06	スタッフAPIの保護	Bearerトークンを付けずにスタッフAPI(開栓等)を直接呼ぶ	401 (UNAUTHORIZED) が返る
ST-07	バッチAPIの保護	X-Cron-Secretを付けずに daily_clear を呼ぶ	401 が返り、卓がクリアされない
ST-08	レート制限	セッション取得APIを1分間に11回以上呼ぶ	11回目以降に429 (RATE_LIMITED) が返る
ST-09	不正なステータス遷移	served の明細に対して cancelled への変更APIを直接呼ぶ	409 (INVALID_STATUS_TRANSITION) が返る
ST-10	RLSの有効化	Supabase管理画面で全5テーブルのRLS状態を確認する	全テーブルが RLS Enabled になっている

ST-01 / ST-05 は特に重要

ST-01が失敗する場合、悪意のある客が他の卓に勝手に注文を追加できる状態にある。ST-05が失敗する場合、ブラウザから直接データベースを読み書きできる状態にあり、全顧客の注文情報が漏洩し得る。いずれも導入を中止して修正すべき水準の問題である。

5. 自動テスト推奨項目(pytest)

対象	テスト内容
セッション検証	正しいtokenで200、誤ったtokenで403、token未指定で403、会計済セッションで403となること
ステータス遷移	pending→served / served→pending / pending→cancelled が成功し、served→cancelled と cancelled→任意が409となること
金額計算	参考小計が単価×数量の合計と一致し、cancelled明細が除外されること。店頭メニューの記載額と1円もずれないこと
開栓の排他制御	同一卓への連続開栓で2回目が409となること
カスタム明細	手入力した税込価格がそのまま小計に反映されること

6. 実験導入時の評価項目

本システムの目的は[00]1章のとおり「顧客体験の向上」と「スタッフ負荷を増やさないこと」である。導入後2～4週間を目安に、以下を確認して継続/改修/中止を判断する。

観点	確認方法	判断の目安
顧客体験	1卓あたりの注文点数・追加注文の回数を導入前後で比較する	追加注文が増えていれば、注文しやすさの改善が実現できている
スタッフ負荷	スタッフへのヒアリング(操作が増えていないか、巡回が減ったか)	「楽になった」という評価が得られること。「操作が増えた」場合は該当機能の見直しが必要
安定性	営業中のエラー発生・問い合わせ件数を記録する	客からの「使えない」という申告が常態化していないこと
運用の定着	会計クリア漏れ(日次バッチでの強制クリア)の発生頻度	頻発する場合は、クリア操作の導線を見直す

7. 変更履歴

版	主な変更内容
V1.0 (FIX)	新規作成。受入テスト25件、セキュリティ確認10件、自動テスト推奨項目、実験導入時の評価項目を定義。